# Security Logging and Event Monitoring Policy

**Effective Date:**
January 13, 2026

**Category:**
Security

**Scheduled Review:**
January 2027

## 1. Authority

*Executive Order 2016-06, Enterprise Information Technology Governance*

## 2. Document Control

This document replaces, in its entirety, the *Security Logging and Event Monitoring Policy*, dated January 6, 2025.

## 3. Purpose

The purpose of this Information Technology Policy (ITP) is to provide the requirements for security logging and event monitoring.

## 4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

## 5. Policy

For definitions found within this document, refer to the *IT Policy Glossary*.

Agencies under the Governor's Jurisdiction shall leverage the Enterprise Security Information and Event Management (SIEM) platform. Agencies requiring access must contact the Enterprise Information Security Office (EISO) at en-eiso-siem-support@pa.gov to gain access.

Independent agencies that have a SIEM solution or that are looking to procure a new SIEM solution must comply with the requirements outlined in this policy and in the *Security Logging and Event Monitoring Standard.*

If a SIEM solution is deployed within an agency, the responsibility is that of the agency to ensure all monitoring requirements as outlined in the *Security Logging and Event Monitoring Standard* are met. Additionally, Logs and Events from the monitoring system shall be made available to the EISO for centralized monitoring.

The Enterprise Information Security office (EISO) shall own and operate the Enterprise SIEM platform and is responsible for:

- Defining log management standards for ingestion, parsing, enrichment, storage, and retention.
- Developing and maintaining use cases for threat detection, compliance monitoring, and operational awareness.
- Conducting threat monitoring, detection, alerting, and incident escalation.
- Coordinating incident response efforts with agency cybersecurity teams and the Commonwealth Security Operations Center (SOC).

The Enterprise Technology Services Office (ETSO) shall:

- Provide infrastructure support for log forwarding agents, collectors, and secure transport.
- Ensure interoperability with agency and enterprise networks and systems.

Agencies shall:

- Monitor any SIEM solution implemented within their organization.
- Identify and submit critical log sources to EISO for Enterprise SIEM integration.
- Support onboarding efforts, including log forwarding configuration and tuning.
- Cooperate with EISO during incident investigations and threat remediation.
- Ensure agency applications and systems meet EISO logging requirements during development and procurement.
- Ensure administrator activity is logged and monitored in a system not controlled by the administrator (see *Security Logging and Event Monitoring Standard*).
- Enable audit functionality for systems and components tied to individual user accounts.
- Employ technical solutions at the network, host, application, and database tiers to detect anomalous activity.
- Ensure mechanisms are in place (in coordination with EISO) to retrieve and report on logged events, particularly those ingested into the Enterprise SIEM.
- Review logs according to the timelines defined below, ensuring anomalies or incidents are detected and escalated.
- Report suspected or confirmed security incidents, and corresponding remediation, in a timely manner per the *IT Security Incident Reporting Policy*.
- Ensure compliance with any additional federal requirements or other obligations they may be subject to (e.g., HIPAA, IRS Pub 1075, CJIS Security Policy, PCI).

### 5.1 SIEM Data Protection

Access to the Enterprise SIEM shall be role-based and must follow the principle of least privilege. Agency security teams shall be granted read-only access to relevant dashboards and log views.

Data in the SIEM shall only be used for cybersecurity operations, incident response, audit, and compliance activities. Any other use must be approved by EISO.

### 5.2 Log Collection Requirements

All agencies shall configure the following log types for integration into the Enterprise SIEM platform, subject to prioritization and feasibility as defined by EISO:

- Operating System Logs (e.g., Windows Event Logs, Linux Syslog)
- Firewall, Web Application Firewall (WAF), Virtual Private Network (VPN), Web

Filter/Proxy, and Intrusion Detection/Prevention System (IDS/IPS) Logs

- Authentication Logs (e.g., Active Directory, Multi-Factor Authentication (MFA), Single Sign-On (SSO))
- Endpoint Protection Logs (e.g., Endpoint Detection and Response (EDR), Extended Detection and Response (XDR) agents)
- Application, Network Time Protocol (NTP), Mail, File Transfer Protocol (FTP), and Web Server Logs
- Cloud Security Logs (e.g., Amazon Web Services (AWS) CloudTrail, Azure Active Directory (Azure AD) logs)
- Audit Logs for compliance-sensitive systems (e.g., Criminal Justice Information Services (CJIS), Health Insurance Portability and Accountability Act (HIPAA), Internal Revenue Service (IRS))
- Core network equipment logs (e.g., switches, routers)
- Domain Name System (DNS) Server Logs
- Dynamic Host Configuration Protocol (DHCP) Logs
- Vulnerability Management Software Logs
- Remote Access and Virtualization Management Logs
- Database Logs

Where third parties are hosting and managing IT resources for an agency, contractual obligations shall include considerations for capturing log information.

## 6. Contact

Questions or comments may be directed via email to OA, IT Policy.

## 7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy exception shall be submitted via the IT policy exception process. Refer to *IT Policy Governance Policy* for guidance.

## 8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

| Version | Date | Purpose of Revision |
|---|---|---|
| Original | 01/06/2025 | Base Document |
| Revision | 01/13/2026 | Strengthened language to require use of the Enterprise SIEM for agencies under the Governors Jurisdiction.<br>Restructured the policy to indicate the responsibility of EISO, ETSO, and Agencies.<br>Added details around log protection in the enterprise SIEM.<br>Clarified which logs are required to be sent to the enterprise SIEM. |